

HACKER WOMAN

Curso Profesional de Hacking Ético CEHPC

DESARROLLO ACTIVIDAD Nro 01

CASO: AURORA MARKET

ANÁLISIS Y PLANIFICACIÓN DE PENTEST

Nombre Completo: Rocío Milagros MEZA PIO

Hacker Woman Council – Ethical hacking

1. OBJETIVO DEL PENTEST:

El presente Pentest plantea los siguientes objetivos:

1.1. **Objetivo 1: Investigar y esclarecer la causa raíz del incidente reportado por el cliente**

- **Detalle Técnico:** Determinar con exactitud si el reporte de visualización no autorizada de datos entre cuentas se debe a un error de la aplicación, a un problema de permisos, a una configuración incorrecta o a una posible vulnerabilidad de la aplicación.
- **Contribución a Aurora Market:** Aportará certidumbre técnica objetiva sobre lo sucedido, eliminando la incertidumbre del equipo directivo.

1.2. **Objetivo 2: Identificar, evaluar y clasificar holísticamente las vulnerabilidades en la aplicación web**

- **Detalle Técnico:** Realizar una auditoría integral de seguridad sobre todas las funciones críticas de la plataforma web, descubriendo fallos de inyección, fallos de autenticación, almacenamiento inseguro de contraseñas, configuraciones defectuosas y debilidades en la API o componentes de terceros.
- **Contribución a Aurora Market:** Permitirá la transición de la empresa desde una postura reactiva actual, es decir de estar corrigiendo fallos cuando ocurren o explotan, hacia una mejor postura de seguridad, es decir, estrategia defensiva proactiva basada en la gestión del riesgo de TI, antes de que ciberdelincuentes reales puedan explotar las brechas.

1.3. **Objetivo 3: Proteger la información sensible y preservar la confianza de los clientes**

- **Detalle Técnico:** Validar la efectividad de las acciones implementadas para la custodia de datos personales (nombres, correos electrónicos, números telefónicos, direcciones de entrega e historial de compras) y verificar el cumplimiento de mejores prácticas de privacidad.
- **Contribución a Aurora Market:** Protege el activo reputacional más valioso del e-commerce: la confianza del consumidor. Asimismo, permitirá prevenir posibles sanciones regulatorias por incumplimiento en la protección de datos personales y garantizar la continuidad operativa sustentable del negocio.

En resumen estos 3 objetivos planteados permitirán a la empresa “Aurora Market” conocer qué tan segura se encuentra la Aplicación Web, conocer qué tan expuesto se encuentra la aplicación ante posibles ataques cibernéticos, conocer y entender cada uno de los riesgos que cuenta la Aplicación Web, conocer además el impacto que puede causar cada uno de ellos al negocio de no ser mitigados. Entendiendo todo ello la empresa podrá plantear un Plan de Acción tomando en cuenta la priorización, y en consecuencia la empresa podrá mantener protegida la confianza de sus clientes.

2. ALCANCE:

2.1. Se evaluará:

- Aplicación Web de Aurora Market autorizada (Dominio/URL oficial asignado).
- Módulo Frontend de Clientes: Registro, inicio de sesión, catálogo de productos, carrito de compras, checkout y consulta de estado de pedidos.
- Panel Administrativo de la Empresa: Funcionalidades internas de gestión de productos, usuarios y pedidos.
- Mecanismos de Autenticación y Autorización: Control de acceso a datos de perfil y roles de usuario.
- PI REST / Endpoints de comunicación entre la aplicación web y el servidor backend.
- Base de Datos asociada a la aplicación web (únicamente en interacción indirecta vía web).

2.2. Queda fuera del alcance:

- Redes sociales oficiales de Aurora Market (Facebook, Instagram, WhatsApp, etc.).
- Equipos informáticos personales de los empleados (PCs, laptops, celulares particulares).
- Cuentas de correo electrónico corporativo o servidores de correo de la empresa.
- Infraestructura de proveedores externos de pago
- Sistemas informáticos o servicios alojados de proveedores de infraestructura externa.
- Instalaciones físicas, centros de cómputo u oficinas de la empresa.

3. AUTORIZACIÓN Y CONDICIONES:

El equipo deberá tener en cuenta las siguientes consideraciones :

3.1. Autorización:

“Aurora Market” proporciona autorización formal al equipo de Ethical Hacking mediante documentación.

3.2. Condiciones:

El Equipo Ethical Hacking se registrará al cumplimiento de las siguientes condiciones establecidas:

- El equipo de Ethical Hacking debe realizar la evaluación únicamente sobre la “Aplicación Web autorizada”
- El equipo no debe realizar ataques a las redes sociales de la empresa “Aurora Market”.
- El equipo no debe realizar ataques a equipos personales de los empleados de “Aurora Market”

- El equipo no debe realizar ataques a correos de los empleados de “Aurora Market”
- El equipo no debe realizar ataques a proveedores externos de la empresa “Aurora Market”
- El equipo no debe realizar ataques ningún otro sistema que no forme parte del alcance ya definido.
- El equipo no debe realizar ninguna otra acción o acciones que puedan provocar interrupción o continuidad de la funcionalidad de la plataforma o que puedan afectar información real de los clientes, es decir, se debe mantener la integridad de la información.
- Si el equipo requiere realizar pruebas, lo deberá realizar en horarios donde haya menor actividad, con el fin de reducir cualquier posible impacto sobre las operaciones.
- Si el equipo encontrara cualquier problema durante el proceso, deberá cumplir con documentar de forma cuidadosa, de tal modo que sea revisado por el equipo de desarrollo.

4. TIPO DE PENTEST:

Basado en la información brindada por “Aurora Market”, donde se indica que Aurora Market “ no entrega toda la información técnica”, el tipo de Pentest que se aplicará corresponden a un **“Pentest Gray Box”** por las siguientes razones claves:

Nivel de Información Disponible: La empresa no proporciona la totalidad de la información técnica, es decir no entrega código fuente, ni diagramas de arquitectura interna, pero sí confirma la existencia de componentes clave tales como: la aplicación web, la base de datos, los mecanismos de autenticación y diferentes tipos de usuarios (clientes y administradores). Tampoco brinda información sobre cómo está construida la plataforma, ni qué tecnologías utiliza.

5. PLANIFICACIÓN:

Antes de enviar cualquier paquete o ejecutar herramientas de escaneo, el equipo de Ethical Hacking estructurará la fase de planificación operativa cubriendo los 7 pilares fundamentales:

5.1. Alineación de Objetivos: Consensuar con la gerencia de Aurora Market los tres objetivos estratégicos (esclarecer el incidente, auditar la web y proteger los datos), asegurando que los hallazgos tengan valor técnico y comercial directos.

5.2. Delimitación Definitiva del Alcance: Confirmar los endpoints oficiales de producción, excluyendo categóricamente infraestructuras de terceros (pasarelas de pago) y entornos de redes sociales.

5.3. Formalización de Permisos y Condiciones: Asegurar la firma del documento “Permisos y Condiciones”, y la exención de responsabilidad legal, fijando las ventanas operativas nocturnas para la ejecución de pruebas que se requieren.

5.4. Selección de la Metodología Estándar: Adoptar marcos metodológicos reconocidos internacionalmente: OWASP Testing Guide v4.2 (para la auditoría de aplicaciones web) y PTES (Penetration Testing Execution Standard) para la gestión del proyecto.

5.5. Recopilación de Información Previa (OSINT Inicial): Recabar datos públicos del dominio de Aurora Market mediante registros DNS, certificados SSL/TLS, tecnologías detectadas desde el exterior (servidor web, cabeceras HTTP) sin realizar interacciones invasivas.

5.6. Definición de Recursos Necesarios:

- Equipo Humano: 1 Lead Ethical Hacker, 1 Especialista en AppSec / Web Pentesting.
- Software & Hardware: Burp Suite Professional, OWASP ZAP, Nmap, Metasploit Framework, Python Scripts personalizados, VPN segura y entorno controlado en Kali Linux.

5.7. Programación y Cronograma Operativo: Establecer una Gantt simplificada para la ejecución ordenada del proyecto, considerando Fase del Proyecto, Descripción de tareas, Nro de Días de Ejecución, Plazos – Duración, Descripción, Responsables.

6. FASES DE PENTEST:

6.1. Reconocimiento

- **Mapeo Integral de la Superficie de Ataque Expuesta:**
 - **Objetivo:** Descubrir todos los puntos de entrada accesibles públicamente o desde distintos niveles de privilegio.
 - **Acciones:** Identificar endpoints no documentados, API REST/GraphQL expuestas, paneles administrativos de gestión, carpetas ocultas, puertos abiertos y servicios o dependencias de terceros expuestos.
- Detectar servidor web, lenguaje/framework del backend y gestor de base de datos mediante inspección de cabeceras HTTP, cookies de sesión.
- Mapeo Operativo de Rutas: Enumerar la estructura completa del sitio web: endpoints de clientes.
- Análisis de Parámetros URL y HTTP: Identificar cómo la aplicación transmite identificadores de usuario y pedido.

6.2. Análisis de Vulnerabilidades

- **Identificación y Clasificación de Vulnerabilidades Existentes:**
 - **Objetivo:** Detectar fallos de seguridad en la aplicación mediante técnicas manuales y automatizadas.
 - **Acciones:** Buscar vulnerabilidades críticas basadas en estándares internacionales como el **OWASP Top 10** (Inyección SQL, Cross-Site Scripting [XSS], Referencias Directas Inseguras a Objetos [IDOR], fallos de autenticación, almacenamiento inseguro de datos y desconfiguraciones de seguridad).

6.3. Explotación

- **Demostración de Explotabilidad y Alcance (Prueba de Concepto - PoC):**
 - **Objetivo:** Determinar si las vulnerabilidades detectadas pueden ser explotadas efectivamente por un atacante real y hasta qué punto.
 - **Acciones:** Ejecutar cargas útiles (*payloads*) no destructivas para validar si es posible eludir mecanismos de seguridad (como Web Application Firewalls - WAF), omitir controles de autenticación o eludir la lógica de negocio.
- **Demostración de Escalado de Privilegios:** Intentar acceder a rutas del panel de administración (`/admin/products``) utilizando una sesión válida de cliente estándar para verificar la separación de roles.

6.4. Post Explotación

- **Determinar** el alcance del riesgo empresarial en un escenario hipotético de compromiso:
 - **Determinación de la Capacidad de Post-Explotación y Pivoteo:**
 - **Objetivo:** Evaluar si el compromiso de la aplicación web puede servir como vector inicial para comprometer elementos más profundos de la infraestructura.
 - **Acciones:** Analizar si un fallo en la app web permite la ejecución remota de código (RCE), el movimiento lateral hacia la red interna o el acceso directo al servidor de base de datos.
 - **Valoración del Impacto en Datos de Clientes:** Evaluar qué cantidad de registros sensibles (nombres, teléfonos, correos, direcciones) se podrían haber cosechado de forma automatizada mediante la vulnerabilidad identificada.
 - **Análisis de Movimiento Lateral e Infraestructura:** Determinar si el compromiso de la aplicación web permitiría al atacante pivotar hacia la base de datos subyacente o comprometer el servidor del hosting.

6.5. Informe

Consolidación y comunicación formal de los hallazgos al equipo directivo y técnico de Aurora Market:

1. Reporte Ejecutivo para Dirección: Resumen no técnico en lenguaje de negocio. Incluye matriz de riesgos (Alto, Medio, Bajo), resumen del estado de seguridad de la tienda y el nivel de exposición de los clientes.
2. Reporte Técnico para Desarrolladores Detallado de cada vulnerabilidad encontrada, evidencia fotográfica / Logs, puntuación CVSS v3.1, pasos exactos para reproducir y recomendaciones directas de remediación en código
3. Re-Testing (Validación Posterior): Oferta de una segunda ventana de pruebas para validar que los parches aplicados por los desarrolladores hayan solucionado definitivamente los problemas reportados.